Ce qu'il ne faut pas faire

- Oublier l'impact pour les personnes et seulement considérer l'impact pour l'organisme.
- Omettre une partie du traitement (ex. : collecte, partenaires, fin de vie des données) pour mener l'analyse.
- Ajuster les échelles de vraisemblance et de gravité pendant l'analyse au lieu de les définir en amont, en prenant en compte le contexte de l'organisme.

POUR ALLER PLUS LOIN

- Le RGPD introduit les **analyses d'impact relatives à la protection des données** (AIPD) et précise que celles-ci doivent au moins contenir « *une description [...] des opérations [...] et des finalités du traitement [...], une évaluation de la nécessité et de la proportionnalité [...], une évaluation des risques [...] et les mesures envisagées pour faire face aux risques [...] et visant à apporter la preuve du respect du règlement* » (article 35.7).
- La CNIL a publié des guides[90] permettant de mener une AIPD. La CNIL a également publié un logiciel pour faciliter la conduite et la formalisation d'AIPD[91].
- La CNIL a également publié des listes de traitements pour lesquels une AIPD est requise[92] ou non[93].
- **Les audits de sécurité sont un moyen essentiel pour évaluer le niveau de sécurité des systèmes sur lesquels reposent les(s) traitement(s) de données personnelles**. Réalisés de façon périodique, ils permettent de prendre en compte les évolutions du traitement et des menaces. Chaque audit doit donner lieu à un plan d'action dont la mise en œuvre devrait être suivie au plus haut niveau de l'organisme.
- **L'étude des risques sur la sécurité de l'information[94] peut être menée en même temps que l'étude des risques sur la vie privée**. Ces approches sont compatibles.
- L'étude des risques permet de déterminer des mesures de sécurité à mettre en place. Il est nécessaire de **prévoir un budget** pour leur mise en œuvre.

90 « Les guides AIPD (analyse d'impact relative à la protection des données) », cnil.fr

91 « Outil PIA : téléchargez et installez le logiciel de la CNIL », cnil.fr

92 « Analyse d'impact relative à la protection des données : publication d'une liste des traitements pour lesquels une analyse est requise », cnil.fr

93 « Analyse d'impact relative à la protection des données : publication d'une liste des traitements pour lesquels une analyse n'est pas requise », cnil.fr

94 Par exemple à l'aide de la méthode EBIOS RM (voir « La méthode EBIOS Risk Manager », cyber.gouv.fr), la méthode de gestion des risques publiée par l'ANSSI, agence rattachée au Secrétariat général de la défense et de la sécurité nationale (SGDSN). EBIOS est une marque déposée du SGDSN.